

KI-Richtlinie Muster 2026: Vorlage für 50-Mitarbeiter-Unternehmen

KURZE ANTWORT

Der Beitrag gliedert eine KI-Richtlinie für einen Betrieb mit rund 50 Mitarbeitern in **zwölf Kapitel**, von Zweck und Rollen über eine Whitelist erlaubter Werkzeuge, Verbote, Datenklassifikation und Prompt-Regeln bis zu Incident-Handling, Mitbestimmung und Review-Rhythmus. Zwei Kapitel greifen die KI-Verordnung auf, die Kennzeichnung nach Artikel 50 und die Schulung nach Artikel 4, der seit dem **2. Februar 2025** gilt und Betreiber anhält, die KI-Kompetenz ihres Personals zu unterstützen. Für die Praxis nennt der Text eine Grundschulung binnen 30 Tagen nach Eintritt, eine Sonderschulung binnen 60 Tagen bei neuen Werkzeugen und die 72-Stunden-Meldefrist der DSGVO. Der Rollout ist mit 4 Wochen für die Erstellung und 3 Monaten Umsetzung veranschlagt. SkillSprinters ordnet solche Compliance-Themen im Blog für den Mittelstand ein.



Geschrieben von [Dr. Jens Aichinger](#) · Gründer von SkillsSprinters, DEKRA-AZAV-zertifizierter Bildungsträger, Autor von 77 Büchern, darunter zahlreiche zur IHK-Prüfungsvorbereitung

AUF EINEN BLICK

Eine schriftliche KI-Richtlinie ist gesetzlich nicht vorgeschrieben, aber sinnvoll: Art. 4 KI-VO verlangt, die KI-Kompetenz zu unterstützen, eine Nachweispflicht gibt es nicht, eine dokumentierte Richtlinie hilft aber im Streitfall. Eine Vorlage für 50-MA-Mittelständler umfasst zwölf Kapitel von Whitelist bis Review-Rhythmus.

Eine schriftliche KI-Richtlinie ist kein Verwaltungsballast, aber auch keine gesetzliche Pflicht. Seit dem 2. Februar 2025 verpflichtet Artikel 4 der KI-Verordnung dazu, die Entwicklung der KI-Kompetenz der Beschäftigten zu unterstützen, ohne für Einzelne ein bestimmtes Kompetenzniveau zu garantieren. Eine dokumentierte Richtlinie ist nicht vorgeschrieben, hilft aber im Schadensfall. Gleichzeitig fordern BAG-Rechtsprechung, DSGVO und der Haftungsschutz deiner Geschäftsleitung ein klares Regelwerk. Dieser Artikel zeigt dir die zwölf Kapitel, die deine KI-Richtlinie für einen 50-MA-Mittelständler enthalten muss, jeweils mit konkretem Formulierungsvorschlag.

Warum eine KI-Richtlinie jetzt unverzichtbar ist

Drei Treiber erzwingen eine formelle Richtlinie. Erstens die KI-VO: Artikel 4 verlangt, die KI-Kompetenz zu unterstützen, Artikel 50 verlangt eine Kennzeichnungspflicht bei bestimmten KI-Outputs. Ab August 2026 kommen Pflichten für Hochrisiko-KI hinzu (Artikel 6ff), wobei der Digital-Omnibus-Trilog am 28. April 2026 eine Verschiebung auf 2027 diskutiert. Zweitens die

wenn aus unbedarftem KI-Einsatz ein Schaden entsteht und keine organisatorische Vorsorge dokumentiert ist.

Ohne Richtlinie bedeutet: Jeder Mitarbeiter darf alles, keiner haftet, niemand weiß es besser. Das ist nicht nur rechtlich riskant, sondern auch operativ. In den kommenden Kapiteln findest du die Struktur einer praktikablen Richtlinie, die du mit deinen Verantwortlichen anpasst.

Kapitel 1: Zweck und Geltungsbereich

Dieser Paragraph regelt, worum es geht und für wen. Konkret: "Diese Richtlinie regelt den Einsatz künstlicher Intelligenz in der Musterfirma GmbH. Sie gilt für alle Beschäftigten, freien Mitarbeiter, Praktikanten und Dienstleister, die im Rahmen ihrer Tätigkeit KI-Systeme einsetzen oder deren Outputs verwenden." Definiere auch, was KI im Sinne dieser Richtlinie ist: generative KI wie ChatGPT, Claude, Gemini; eingebettete KI wie Microsoft Copilot; branchenspezifische KI-Module in Fachsoftware; KI-gestützte Entscheidungssysteme (HR, Kredit, Risikobewertung).

Vom Fachartikel zur eigenen Anwendung

Über Digitalisierung zu lesen ist das eine, sie im Arbeitsalltag umzusetzen das andere. Der KI-Schnupperkurs zeigt in fünf kurzen Lektionen, wie Prozesse mit KI und Automatisierung konkret aussehen. Wer danach tiefer einsteigen will, findet im Digitalisierungsmanager die Weiterbildung dazu, bei bewilligtem Bildungsgutschein ohne Kosten für dich.

Kostenlos reinschnuppern

Der Schnupperkurs ist gratis. Ob die Weiterbildung über den Bildungsgutschein gefördert wird, entscheidet die Agentur für Arbeit im Einzelfall.

Kapitel 2: Rollen und Verantwortliche

Klare Zuständigkeiten sind der halbe Schutz. Folgende Rollen sollten benannt werden:

Rolle	Verantwortung	Typische Besetzung
Geschäftsleitung	Gesamtverantwortung, Budgetfreigabe, jährliche Genehmigung der Richtlinie	Geschäftsführer

Datenschutzbeauftragter (DPO)	DSGVO-Prüfung jedes neuen KI-Tools, Auftragsverarbeitungsverträge	Interner DPO oder externe Kanzlei
IT-Leitung	Technische Kontrollen, Zugriffsrechte, Monitoring	IT-Leiter
Betriebsrat	Mitbestimmung bei neuen KI-Tools, Betriebsvereinbarung	gewählt
Führungskräfte	Umsetzung in der Abteilung, Eskalation	alle Abteilungsleiter
Alle Beschäftigten	Einhaltung der Regeln, KI-Kompetenzpflicht, Meldepflicht bei Vorfällen	alle

Kapitel 3: Erlaubte Tools (Whitelist)

Hier führst du konkret auf, welche KI-Systeme im Unternehmen genutzt werden dürfen. Ohne Whitelist wächst Schatten-KI und macht dich haftbar. Beispielstruktur: "Für dienstliche Zwecke sind ausschließlich folgende KI-Tools zulässig: Microsoft Copilot im Rahmen des Microsoft 365 Business Enterprise Plans, Claude Team über den Firmenaccount, DeepL Pro, Grammarly Business. Die Nutzung weiterer KI-Tools bedarf der vorherigen schriftlichen Freigabe durch die IT-Leitung und den Datenschutzbeauftragten."

Wichtig: Jedes Tool auf der Whitelist braucht einen dokumentierten Freigabe-Prozess: DSGVO-Prüfung, Auftragsverarbeitungsvertrag, Risiko-Klassifikation nach KI-VO, Incident-Response-Ansprechpartner.

Kapitel 4: Verbote

Klartext, was niemand tun darf:

- Keine Nutzung privater KI-Accounts (z.B. privates ChatGPT-Konto) für Firmendaten.
- Keine Eingabe von personenbezogenen Daten, Betriebsgeheimnissen, Kundendaten oder sicherheitsrelevanten Informationen in KI-Tools ohne gültigen Auftragsverarbeitungsvertrag.
- Kein Einsatz von KI für Personalentscheidungen (Einstellung, Beförderung, Entlassung) ohne menschliche Letztentscheidung und schriftliche Dokumentation.
- Keine Veröffentlichung von KI-generierten Texten oder Bildern ohne interne Qualitätsprüfung.

Kapitel 5: Datenklassifikation

Bevor du KI einsetzt, müssen deine Mitarbeiter wissen, welche Daten wo landen dürfen.

Einführung einer vierstufigen Klassifikation:

Stufe	Inhalt	KI-Nutzung
Öffentlich	Pressemeldungen, Produktbroschüren, Website-Texte	Jedes freigegebene KI-Tool
Intern	Interne Memos, Projektpläne ohne Kundenbezug, interne Schulungen	Nur Tools mit Auftragsverarbeitungsvertrag
Vertraulich	Strategie, Finanzzahlen, Verhandlungsmaterial	Nur on-premises oder abgeschottete KI-Umgebungen
Personenbezogen	Kundendaten, Mitarbeiterdaten, Gesundheitsdaten	Nur mit expliziter Freigabe durch DPO und dokumentiertem AVV

Kapitel 6: Prompt-Regeln

Praktische Anweisung für den Arbeitsalltag. Zum Beispiel:

1. Keine echten Namen, E-Mail-Adressen, Telefonnummern oder Kundennummern in Prompts. Platzhalter nutzen ("Kunde X", "Mitarbeiter Y").
2. Keine vertraulichen Vertragsinhalte in öffentliche KI-Tools. Bei interner Nutzung pseudonymisieren.
3. Keine Gesundheitsdaten, politische Meinungen, Gewerkschaftszugehörigkeit (besondere Kategorien nach Artikel 9 DSGVO).
4. Keine Sicherheitsdaten: Passwörter, API-Keys, Netzwerkkonfigurationen.
5. Bei Zweifeln: Vorgesetzten oder KI-Beauftragten fragen, bevor der Prompt abgeschickt wird.

Kapitel 7: Output-Verantwortung

Ein generierter Text ist kein Freibrief. Der Mensch prüft, der Mensch signiert. Formuliere: "Der Mitarbeiter, der einen KI-generierten Output freigibt (z.B. E-Mail an Kunden, Vertragstext, Social-

Kapitel 8: Kennzeichnungspflicht Artikel 50 KI-VO

Drei Fälle, in denen du aktiv kennzeichnen musst:

- **Chatbots:** Nutzer müssen wissen, dass sie mit einer Maschine sprechen. Formulierung: "Ich bin ein KI-Assistent. Bei komplexen Anliegen leite ich dich an einen Menschen weiter."
- **Deepfakes und KI-generierte Medien:** Bilder, Videos, Audio-Aufnahmen, die Personen zeigen oder imitieren, müssen als KI-generiert gekennzeichnet sein, sofern sie nicht offensichtlich satirisch oder künstlerisch sind.
- **Synthetische Inhalte:** Texte, die durch KI erzeugt und im öffentlichen Interesse verbreitet werden (z.B. News-Artikel), sind kennzeichnungspflichtig, sofern sie nicht menschlich geprüft und redaktionell verantwortet wurden.

Kapitel 9: Schulung nach Artikel 4 KI-VO

Diese Pflicht gilt seit 2. Februar 2025 und betrifft alle, die KI einsetzen. Die Richtlinie konkretisiert:

1. Alle neuen Mitarbeiter erhalten binnen 30 Tagen nach Eintritt eine Grundschulung zur KI-Nutzung (2 Stunden, interaktiv).
2. Jährliche Auffrischung für alle Mitarbeiter (1 Stunde).
3. Rollenspezifische Vertiefung: Führungskräfte, HR-Verantwortliche, Einkauf, Marketing jeweils 2 Stunden pro Jahr.
4. Nachweisführung: Teilnehmerlisten, Lernkontrollen, Zertifikate fünf Jahre aufbewahren.
5. Bei neuen Tools oder Gesetzesänderungen: Sonderschulung innerhalb von 60 Tagen.

Kapitel 10: Incident-Handling

Was passiert, wenn etwas schief geht. Beispiele für meldepflichtige Vorfälle:

- Ein Mitarbeiter hat Kundendaten in ein nicht freigegebenes KI-Tool eingegeben.
- Eine KI hat eine fehlerhafte Empfehlung gegeben, die Schaden verursachen könnte.
- Ein Kunde beschwert sich über diskriminierende KI-Antwort.
- Ein Datenleck über ein KI-System wurde festgestellt.

Kapitel 11: Mitbestimmung und Betriebsvereinbarung

Wenn ein Betriebsrat besteht, braucht die Richtlinie eine ergänzende Betriebsvereinbarung.

Kernthemen:

- Welche KI-Tools werden eingesetzt?
- Zu welchem Zweck?
- Gibt es Leistungs- oder Verhaltenskontrolle?
- Welche Daten werden verarbeitet und wie lange gespeichert?
- Welche Rechte haben Beschäftigte (Einsicht, Widerspruch, Korrektur)?
- Wie läuft die Schulung ab?

Ohne Betriebsvereinbarung bei mitbestimmungspflichtigen Themen ist der Einsatz rechtlich angreifbar. Der Betriebsrat kann in solchen Fällen eine einstweilige Verfügung erwirken.

Kapitel 12: Review-Rhythmus

Eine Richtlinie, die einmal geschrieben und nie wieder angefasst wird, ist wertlos. Setze klare Zyklen:

- Jährliche Komplettüberprüfung durch KI-Beauftragten, DPO und IT-Leitung.
- Halbjährlich Überprüfung der Whitelist.
- Quartalsweise Lagebericht an die Geschäftsleitung.
- Ad-hoc bei: neuen gesetzlichen Anforderungen, kritischen Vorfällen, Einführung neuer Tools.

Vom Fachartikel zur eigenen Anwendung

Über Digitalisierung zu lesen ist das eine, sie im Arbeitsalltag umzusetzen das andere. Der KI-Schnupperkurs zeigt in fünf kurzen Lektionen, wie Prozesse mit KI und Automatisierung konkret aussehen. Wer danach tiefer einsteigen will, findet im Digitalisierungsmanager die Weiterbildung dazu, bei bewilligtem Bildungsgutschein ohne Kosten für dich.

Kostenlos reinschnuppern

Wer muss die Richtlinie unterzeichnen?

Drei Unterschriften sind üblich: Geschäftsleitung (gibt die Richtlinie frei), Betriebsrat (bestätigt Mitbestimmung), Datenschutzbeauftragter (bestätigt DSGVO-Konformität). Alle Mitarbeiter bestätigen den Empfang und die Kenntnisnahme schriftlich oder elektronisch. Ohne Empfangsbestätigung ist der Nachweis der Unterweisung brüchig.

Rollout-Plan für einen 50-MA-Betrieb

1. **Woche 1:** Entwurf der Richtlinie durch KI-Beauftragten, DPO und externe Beratung.
2. **Woche 2:** Abstimmung mit Geschäftsleitung, IT, Betriebsrat.
3. **Woche 3:** Betriebsvereinbarung verhandeln, anwaltlicher Gegencheck.
4. **Woche 4:** Freigabe durch Geschäftsleitung, Kick-off-Event mit allen Mitarbeitern.
5. **Monat 2:** Schulungen durchführen, Empfangsbestätigungen einsammeln, erste Audits.
6. **Monat 3:** Feedback-Schleife, Anpassung, Einarbeitung in neue Arbeitsverträge.

Wichtiger Hinweis zum rechtlichen Gegencheck

Die hier skizzierte Struktur ist eine Orientierungshilfe, kein Download zum 1:1-Einsatz. Jedes Unternehmen hat besondere Risiken, Sektoren und Tariflagen. Vor der Inkraftsetzung empfehlen wir dringend einen Gegencheck durch eine Anwaltskanzlei mit Schwerpunkt Arbeits- und Datenschutzrecht. Kosten liegen illustrativ bei 1.500 bis 3.500 Euro, deutlich günstiger als ein falscher Satz im Abmahnfall.

Was du diese Woche tun solltest

1. Prüfe, ob es in deinem Unternehmen bereits einen schriftlichen KI-Rahmen gibt (inoffizielle Mails zählen nicht).
2. Benenne eine verantwortliche Person für KI-Compliance (in Teilzeit reicht initial).
3. Erstelle eine Inventur aller genutzten KI-Tools über einen anonymen Fragebogen an alle Abteilungen.
4. Plane einen Termin mit Betriebsrat, DPO und Geschäftsleitung zur Vorbereitung der Richtlinie.
5. Sichere ein Budget für externe Rechtsberatung.

durch Anfragen der Aufsichtsbehörden oder durch interne Vorfälle. Wer jetzt loslegt, hat einen Vorsprung von Monaten.

Häufige Fragen

▼ Ist eine KI-Richtlinie im Mittelstand Pflicht?

Eine dokumentierte KI-Richtlinie ist gesetzlich nicht vorgeschrieben. Art. 4 KI-VO verlangt nur, die KI-Kompetenz zu unterstützen, eine Nachweispflicht gibt es nicht. Ohne Dokumentation stehst du im Schadensfall aber schlechter da, weil fehlende Kompetenz als Organisationsverschulden gewertet werden kann.

▼ Was muss in einer KI-Richtlinie für 50 Mitarbeiter stehen?

Zwölf Kapitel haben sich bewährt: Zweck und Geltungsbereich, Rollen, erlaubte Tools (Whitelist), Verbote, Datenklassifikation, Prompt-Regeln, Output-Verantwortung, Kennzeichnung nach Art. 50, Schulung nach Art. 4, Incident-Handling, Mitbestimmung und Review-Rhythmus. Jedes Kapitel zwei bis vier Sätze reicht.

▼ Muss der Betriebsrat bei einer KI-Richtlinie mitbestimmen?

Ja. Das BAG hat wiederholt klargestellt, dass der Einsatz von KI am Arbeitsplatz mitbestimmungspflichtig ist, sobald Leistungs- oder Verhaltenskontrolle möglich ist (§ 87 Abs. 1 Nr. 6 BetrVG). Die Richtlinie selbst, die Tool-Whitelist und das Monitoring brauchen in Unternehmen mit Betriebsrat eine Betriebsvereinbarung oder Zustimmung.

▼ Wer unterzeichnet die KI-Richtlinie?

Die Geschäftsführung erlässt die Richtlinie. Alle Mitarbeiter, die mit KI arbeiten, sollten den Erhalt und die Kenntnis schriftlich bestätigen, meist per Anlage zum Arbeitsvertrag oder per digitaler Signatur im HR-System. In Unternehmen mit Betriebsrat kommt eine Betriebsvereinbarung hinzu.

KI-Richtlinie umsetzen statt nur schreiben?

DigiMan-Weiterbildung deckt KI-Governance, Richtlinien und Schulung ab. Bis zu 100 % über QCG förderfähig. 15 Minuten kostenloses Erstgespräch.